

Information Security Incident Report Form

Name: Timothy Loudon, Emmanuel Ajayi, Daniel Lindo, Melvin Viado
Email address:
Telephone/Mobile number:
Date of report:
Incident detection date:
Has the incident been resolved (yes/no) Yes
Organization name and address: Name: Discord.io Address: Unknown
Incident Overview
Location of incident (site) Database server
Nature of Incident (select all that apply) (a) Suspicious system and network activities (b) Compromise of sensitive information (c) Unauthorized access or attempts to access a system (d) Emails with suspicious attachments or links (e) Denial of service attacks (f) Suspected tampering of electronic devices (g) Malware infection • Cryptlocker • Coin miner • Remote access trojan • Credential harvesting malware • Botnet • Other malware (describe) (h) Reconnaissance (scanning/probing) (i) Social engineering (j) Account compromise Suspicious system and network activities, unauthorized access or attempts to access a system,
Incident Severity (a) None/Negligible (suspicious activity only) (b) Minor (Impacts single computer, non-privileged account) (c) Moderate (Impacts part of the organization's infrastructure) (d) High (impact's organization's entire infrastructure/privileged accounts) (e) Very High (has impact beyond the organization) High Impact

How did the organization become aware of the incident?

After being notified of the breach and viewing a preview of leaked information the BreachForums website

Provide a general description of the incident:

In August of 2023, a hacker breached the Discord.io database and exfiltrated customer information including email addresses, salted/hashed passwords, Discord user IDs, and a small amount of payment processing information

Incident Report

Incident Impact (select all that apply)

- (a) Loss of access to services
- (b) Loss of productivity
- (c) Loss of reputation
- (d) Loss of revenue
- (e) Propagation to other networks
- (f) Unauthorized disclosure of data/information
- (g) Unauthorized modification of data/information
- (h) Unknown/Other (please describe)

Loss of reputation, unauthorized disclosure of data

What steps were taken to investigate the nature and severity of the incident?

The entire server was shut down to investigate the data breach and remains taken down to this day almost 3 years later

What systems were impacted?

- IP addresses of affected systems:
- FQDN of affected systems:
- Role of affected systems (Domain controller/DNS/DHCP/Web Server):
- Operating systems of affected systems:
- Patch level of affected systems:
- Security software on affected systems:
- Physical location of affected systems:
- Additional details:

The database server's confidentiality and integrity

Which applications were impacted?

The entire customer user database server

What unauthorized data access occurred?

Unauthorized data access to the database server holding customer information

Which privileged user accounts were impacted?

All accounts

Which unprivileged user accounts were impacted?

All accounts

Which third parties were impacted (Vendors/Contractors/Partners)

None

Sensitivity of Compromised Data (select all that apply)

- (a) Confidential/Sensitive data
- (b) Non-sensitive data
- (c) Publicly available data
- (d) Financial data
- (e) Personally identifiable information (PII)
- (f) Intellectual property
- (g) Critical infrastructure/key resources
- (h) Other (describe)

Confidential/Sensitive Information, Financial data, Personally Identifiable Information

What would the consequences be of the data that was accessed in an unauthorized manner becoming public?

Loss of company reputation and lawsuits from customers whose private information was leaked

What is the time frame of the incident?

Suspected initial date/time of compromise: **August 14, 2023, 12:51 AM CET**

Detection date/time: **August 14, 2023, 4:30 PM CET**

Incident remediation date/time: **August 14, 2023, 4:40 PM CET**

How did the breach occur? (select all that apply)

- (a) DDoS
- (b) Malware
- (c) Misconfiguration
- (d) Phishing
- (e) Vulnerability exploit
- (f) Unknown

F) Unknown

Suspected perpetrators:

- (a) Insider
- (b) Former staff
- (c) Other
- (d) Unknown

C) Other (Hacker goes by the name Akhirah)

Estimated total cost incurred: (Cost to contain incident, restore systems, notify stakeholders)

- **Estimated cost to contain the incident ranges between \$150,000 - \$300,00**
- **Estimated Cost to restore systems ranges between \$200,00 - \$400,000**
- **Estimated Cost to refund premium account subscribers ranges between \$100,000 - \$200,000**
- **Total Sum of costs incurred: \$550,000 - \$900,000**

What steps have been taken to remediate the cause of and vulnerabilities related to the incident?

- **Revoke API keys and tokens**
- **Air gap compromised infrastructure for decommission**
- **Enhance the security of the database access controls**
- **Migrate to a more secure hosting platform**
- **Revise the Business Continuity Plan**
- **Adopt a new security framework**
- **Make use of forensics to pinpoint and remediate the breach, along with log analysis**

What additional controls should be in place to prevent the incident reoccurring?

- **ISO 27001:0222 A.5.18: This control is in relation to privileged access rights, to enforce least privilege for database access, routing rotations of API keys, and the implementation of MFA for admin access.**
- **ISO 27001:2022 A8.24: This is a Cryptographic control that enforces strong hashing practices, encrypting sensitive data both in transit and at rest, and the removal of unnecessary data retention.**
- **ISO 27001:2022 A5.32: This control handles intellectual property rights, to ensure there is compliance with intellectual property laws, as Discord.IO has no relation to Discord itself.**
- **ISO 27001:2022 A5.19: this control handles formal vendor risk assessments that are conducted routinely, and the use of annual penetration tests. This would aid in**

overcoming vulnerabilities that may not have been discovered yet, aiding reducing the occurrence of a breach.

Do any authorities need to be notified about the details of the incident?

Due to the nature of the attack involving an illegal exfiltration of data, authorities should be informed of the incident

Additional impact information: